

毕业答辩演讲稿

面向多用户多关键词的可验证可搜索加密方案研究

时长参考：约 15 分钟（每页估时仅供参考）

第 1 页 | 封面

□ 参考时长：约 30 秒

各位老师好，我是网络安全学院的张柏川，我的指导教师是王婧副教授。今天我答辩的论文题目是《面向多用户多关键词的可验证可搜索加密方案研究》，请各位老师批评指正。

第 2 页 | 目录

□ 参考时长：约 30 秒

本次答辩共分七个部分：首先介绍研究背景与意义，随后梳理研究现状与相关工作；第三、四部分分别展开本文的两项核心创新机制；第五部分给出安全性分析；第六部分呈现实验结果；最后进行总结与展望。

第 3 页 | 研究背景

□ 参考时长：约 60 秒

随着企业和个人数据大规模迁移到云端，数据安全面临三类主要威胁：外部渗透、内部越权以及服务提供商的隐私窥探。传统的加密存储方案虽然能保护数据隐私，但代价是明文检索能力的完全丧失——加密之后，数据就无法直接被搜索了。可搜索加密（SSE）正是为解决这一矛盾而提出的：它允许用户在密文上直接执行关键词检索，在保护数据隐私的同时保留检索可用性。

如右侧图示所示，典型 SSE 系统涉及三方：授权管理方持有主密钥并负责令牌签发；授权用户持令牌向云端发起查询，并验证返回结果；云服务器存储加密索引并执行实际的检索操作。SSE 方案经历了从单关键词到合取查询、从静态到动态更新、再到多用户场景的持续演进。

第 4 页 | 核心问题与挑战

□ 参考时长：约 60 秒

然而，现有方案存在一个根本矛盾：恶意云服务器可能偏离协议执行，返回不完整甚至伪造的搜索结果，而授权用户缺乏有效的验证手段。具体来说，本文识别出三类核心攻击：

第一类是判定位伪造。在基于 RBF 的资格检验中，服务器仅输出布尔判定，没有任何密码学凭证，恶意方可以任意伪造“命中”或“未命中”的结论。第二类是地址替换。在 OPRF 盲化架构下，客户端持有采样索引但无法独立重算物理地址，服务器可以将真实的满位地址替换为未授权位置，悄无声息地绕过资格检验。第三类是版本回放。在没有版本锚定的情况下，服务器可以用历史状态来应答当前查询，静默跳过索引的最新更新。现有可验证 SSE 方案大多只对最终结果集做完整性校验，缺乏对检索流程内部——资格检验与地址寻址——的系统性验证能力，这正是本文的切入点。

第 5 页 | 研究意义与本文目标

□ 参考时长：约 45 秒

本文的目标可以概括为一句话：把“不可见的内部检索步骤”转化为具备密码学保障的可验证过程。在理论层面，我们将验证粒度从结果集扩展至位值真实性与地址归属正确性；在方法层面，在保留 OPRF 盲化与概率数据结构优势的前提下引入密码学承诺层；在实践层面，追求轻量级附加开销，适配多用户云端部署场景。为此，本文提出两项核心机制：机制一是基于 Merkle Hash Tree 的可验证资格检验机制 π_{VQ} ，机制二是基于 Merkle 选择性开封的地址绑定验证机制。两者共同依赖 EUF-CMA 签名不可伪造、抗碰撞哈希函数族以及 OPRF 伪随机性三个标准假设。

第 6 页 | SSE 方案演进

□ 参考时长：约 60 秒

在展开本文方案之前，先简要梳理 SSE 领域的演进脉络。从 Song 等人的早期单关键词方案，到支持合取查询的 OXT，再到引入动态更新与前向/后向安全的 ODXT，以及支持多客户端的 MC-ODXT，每一步都在扩展功能边界。本文选择 Nomos 作为基础方案，它代表了当前多用户、动态、多关键词合取 SSE 的最新基线，其核心架构由 TSet 与 XSet 双索引组成，结合 OPRF 盲化实现客户端令牌保护。观察这条演进规律可以发现：可验证性研究始终滞后于功能演进——每次功能扩展之后，配套的验证机制往往要推迟很久才被系统性解决，这为本文提供了明确的研究空白。

第 7 页 | 现有方案局限

□ 参考时长：约 45 秒

如表所示，对现有可验证 SSE 方案进行横向比较：VSSE 类、VCDSSSE 和 EVMK-SSE 的验证对象均停留在集合级，均无法验证内部检索步骤。本文方案的差异在于三点：查询类型扩展至多用户动态合取；验证对象细化到位值、地址与结果三个层次；验证粒度达到位/地址级，且能够验证内部步骤。具体对应三类尚未被解决的核心局限：无法检测位值伪造、无法在 OPRF 盲化下验证地址归属，以及缺乏版本锚定导致的回放漏洞。

第 8 页 | 系统模型

□ 参考时长：约 45 秒

进入本文两项机制的介绍。系统仍然采用三方模型：授权管理方 G 持主密钥，负责版本锚定与令牌绑定；授权用户 C_i 持令牌发起查询，并在本地独立完成验证；云服务器 S 存储双索引 $TSet$ 与 $XSet$ ，执行检索并生成证明。威胁模型设定为恶意但计算受限的云服务器：服务器可以偏离协议，可以观察泄露信息，但不能打破签名不可伪造性与哈希抗碰撞性。两项机制以层叠方式叠加在 Nomos 之上：机制一解决位值真实性，机制二解决地址归属正确性，两者组合构成完整验证链路。

第 9 页 | π_VQ 的设计动机

□ 参考时长：约 60 秒

先看机制一的设计动机。Nomos 的资格检验基于 RBF 概率数据结构，服务器对每个候选项仅输出布尔判定 $\{0, 1\}$ ，没有任何密码学约束。这带来两个问题：一是客户端无法区分真实未命中与恶意伪造的未命中；二是没有版本绑定，服务器可用历史状态应答，静默跳过后续更新。 π_VQ 的核心设计思路是：在 $XSet$ 位数组 $B^{\wedge}(t)$ 上叠加 Merkle Hash Tree 承诺层，同时不改变原有 RBF 采样语义。具体地，对位数组的每个位置 a 构造叶节点承诺 $L_a = H(0 \parallel a \parallel B^{\wedge}(t)[a])$ ，然后自底向上构建 Merkle 树，根节点即为对整个位数组状态的密码学承诺。同时引入版本锚定签名 $Anchor_t = (t, R_X^{\wedge}(t), \sigma_t)$ ，将当前版本号与 Merkle 根绑定到一起。

第 10 页 | π_{VQ} 四个算法

□ 参考时长：约 75 秒

π_{VQ} 由四个算法构成：Commit（授权管理方执行）：对完整位数组构建 QTree。初始化需要 $O(M)$ 次哈希；后续每次动态更新只需 $O(\log M)$ 次增量哈希，与 RBF 更新开销同阶。

TokenBind（授权管理方执行）：将搜索令牌附加当前版本号 t 与采样索引 v ，确保令牌与当前状态强绑定，防止服务器利用旧版令牌回放历史结果。

Search-Prove（服务器执行）：服务器在执行检索的同时生成证据。对于判定为 1 的候选项，生成 k 条满位地址的 Merkle 认证路径（Positive 证据）；对于判定为 0 的候选项，提供至少 1 条零位地址的反例路径（Negative 证据）。Verify（客户端执行）：分三层递进验证。首先验证版本锚定签名，确认响应对应当前版本；其次验证每条路径的哈希链是否指向已绑定的根；最后进行语义校验，确认 Positive 证据中 k 位全为 1，Negative 证据中至少 1 位为 0。

从复杂度角度，更新额外引入 $O(\log M)$ 哈希，验证开销与证明大小成正比，整体轻量。

第 11 页 | 地址替换攻击

□ 参考时长：约 60 秒

有了 π_{VQ} 之后，是否就万事大吉了？答案是否定的。 π_{VQ} 能够验证位值本身的真实性，但无法验证服务器采样的地址是否属于授权集合。攻击场景如下：在 OPRF 盲化下，客户端持有采样索引 v 但不掌握密钥

K_X ，因此无法独立重算物理地址。恶意服务器可以将正确的满位地址 a

替换为授权集合外的零位地址 a 。关键在于，由于 a 确实在 Merkle 树中且该位为 0， π_{VQ} 的路径验证仍然通过——客户端无法检测这一替换，导致合法文件被错误剔除。

这就是地址替换攻击的本质： π_{VQ}

保证了“给定地址对应的位值是真实的”，但没有保证“给定的地址本身是授权的”。

解决思路是对授权地址集合额外建立 Merkle 承诺，只对采样的 k

个位置选择性开封，由客户端验证采样地址确实属于授权集合。

第 12 页 | Merkle-Open 构造

□ 参考时长：约 60 秒

机制二的具体构造如下：更新阶段，授权管理方对每条关系 (j, id) 的 d 维交叉标签集合建立 Merkle 树，并对树根生成认证签名 σ_{rt} 。这一步在数据更新时执行，不增加搜索延迟。

搜索阶段，服务器仅对本次查询采样的 k 个位置进行选择性地开封，返回对应的 x_{tag} 值与 Merkle 认证路径。这里的关键是选择性——只开封 k 个而非全部 $|G|$ 个，从而保护未采样地址的隐私。

客户端验证分三步：验证根认证签名合法；验证每条叶子路径正确指向已绑定的根；最后确认开封出的地址集合确实是令牌指定采样集合的子集。这一设计将单条关系的通信开销从朴素全开封的 $O(|G|)$ 压缩至 $O(k(|G| + \lambda \log |G|))$ ，由于 $k \ll |G|$ ，通信节省非常显著。

第 13 页 | ExistTree

□ 参考时长：约 45 秒

机制二还需要解决一个遗留问题：如果服务器声称某条关系根本不存在，客户端如何判断这是真实不存在还是服务器故意隐匿？为此引入 ExistTree——一棵授权管理方维护的排序 Merkle 树，记录所有曾经写入的关系集合。它同时支持两种证明：对于确实存在的关系，提供标准 Merkle 成员性证明；对于确实不存在的关系，提供相邻叶的间隙证明。结合

ExistTree，地址绑定健全性在两种情况下均可保证：地址替换攻击因 $\text{ProofAddr} \neq A^*(t, v)$ 无法通过验证；存在性伪造因 ExistTree 的成员性矛盾同样无法通过验证。

第 14 页 | 安全性分析

□ 参考时长：约 45 秒

在三个标准密码学假设的基础上，本文形式化证明了两套安全性质。对于

π_{VQ} ：正确性保证诚实执行时客户端以压倒概率接受；绑定健全性保证位值 $B[a]$ 不可被伪造；版本一致性排除了历史状态回放攻击；条件完整性则在候选集完整返回的前提下保证验证不漏报。

对于地址绑定机制：地址替换与存在性伪造两类攻击，分别因 ProofAddr 超出授权集合和 ExistTree 成员性矛盾而被排除。

第 15 页 | 组合可验证性定理

□ 参考时长：约 45 秒

本文的核心理论结果是： π_VQ 与 Merkle-Open

的组合建立了从地址归属正确性到值真实性的完整验证链路。

两项机制在安全性上相互补足：Merkle-Open 保证服务器提供的地址确实属于授权集合； π_VQ 保证该地址对应的位值未被篡改。两者串联，覆盖了内部检索过程中所有可被攻击的环节。在 EUF-CMA 签名不可伪造、抗碰撞哈希函数族以及 OPRF

伪随机性假设下，可以形式化保证组合安全性——这是本文安全分析的主定理。

第 16 页 | 实验设置

□ 参考时长：约 30 秒

下面介绍实验评估部分。实验在 Apple M1、8 核 CPU、16 GB 内存的平台上进行，使用 C++11 实现，密码库选用 OpenSSL、RELIC 和 Ed25519。选取 Nomos 和 MC-ODXT 作为基线方案，在 Crime、Enron、Wiki 三个真实数据集上进行评测。三个数据集的关键词对数量从 450 万到近 800 万不等，覆盖不同规模的实际场景。评估维度包括搜索/更新时间、存储开销、通信开销，以及验证开销随候选集规模的变化趋势。

第 17 页 | 实验

□ 参考时长：一）：客户端搜索时间（约 45 秒）

第一组实验测量客户端搜索时间。如图所示，在 Crime、Enron、Wiki

三个数据集上，本文方案相对 Nomos 基线的客户端搜索时间增量均低于

10%；授权管理方侧的增量低于 5%。搜索时间随候选集规模 m 线性增长，与理论预测的 $O(k|Q|$

• $UpdateCnt[w_s]$) 高度吻合，证明方案的时间复杂度分析是准确的。这一结果说明，在用户可感知的搜索延迟层面，本文的验证机制几乎是透明的。

第 18 页 | 实验

□ 参考时长：二）：服务器与授权管理方时间（约 30 秒）

第二组实验测量服务器侧和授权管理方侧的搜索时间。服务器时间增量低于 20%，主要来自 Merkle 认证路径的生成开销，随候选集规模线性增长，符合理论预测。授权管理方时间增量同样很小，体现了版本锚定签名与令牌绑定操作的轻量性。总体而言，理论分析与实验数据高度吻合。

第 19 页 | 实验

□ 参考时长：三）：存储开销（约 45 秒）

存储开销是本文方案的主要代价。如表所示，服务器存储相对 Nomos 基线有显著增长：Crime 数据集从 765 MB 增至 7.4 GB，增长约 10 倍。这一膨胀来自 MPos 与 MTree 两类结构：MPos 记录位数组中每个采样位置的地址信息，MTree 则是 Merkle 树本身。渐近复杂度为 $O(N \cdot \lambda)$ ，未来可通过压缩哈希或分层存储进一步优化。需要强调的是，客户端存储增量低于 0.1%，对用户几乎完全透明，存储代价完全由服务器承担。

第 20 页 | 实验

□ 参考时长：四）：通信开销（约 30 秒）

最后一组实验测量通信开销。客户端上传增量极低，每次查询仅新增版本号 8 字节与采样索引 8 字节，合计 16 字节，可忽略不计。服务器下发侧，选择性开封将单条关系通信从 $O(|G|)$ 压缩至 $O(k(|G| + \lambda \log \quad))$ ，通信节省显著。综合来看，客户端与通信侧开销几乎可忽略，服务器侧存储是主要代价，整体方案适合多用户云端部署。

第 21 页 | 总结与主要贡献

□ 参考时长：约 60 秒

下面总结本文的三项主要贡献。贡献一：提出基于 Merkle Hash Tree 的可验证资格检验机制 π_VQ 。核心在于将 Nomos 中无凭证的布尔判定，升级为支持双向证据的独立可验证密码学证明，同时引入版本锚定签名。形式化证明了绑定健全性、版本一致性和条件完整性。贡献二：提出基于 Merkle-Open 的地址绑定验证机制，在保护 OPRF 盲化查询隐私的前提下，将授权地址集合的归属验证从不可能变为可能。结合 ExistTree，通信从 $O(|G|)$ 降至 $O(k(|G| + \lambda \log \quad))$ ，并形式化证明了地址绑定健全性。贡献三：两层机制的组合建立了从地址归属正确性到位值真实性的完整验证链路，在 Crime、Enron、Wiki 三个真实数据集上验证了方案的可行性，客户端开销增量低于 10%，理论与实验高度吻合。

第 22 页 | 局限与未来方向

□ 参考时长：约 30 秒

本文也存在若干局限：当前方案依赖服务器如实返回候选条目，尚未覆盖 TSet 链式索引的枚举完整性；服务器侧存储开销相比基线有明显增长；方案目前仅支持合取查询，未扩展至析取或更复杂的布尔组合。未来研究将围绕三个方向展开：对 TSet 链式结构引入 Merkle 承诺以验证枚举完整性；探索 Merkle-Open 在析取与布尔组合查询下的扩展；以及通过泄露与开销建模指导存储裁剪优化。

第 23 页 | 致谢

□ 参考时长：约 15 秒

以上就是我的答辩汇报，感谢王婧副教授多年来的悉心指导，感谢实验室各位师兄师姐的帮助与支持，也感谢家人的理解与鼓励。敬请各位评审老师批评指正，谢谢！